

RAPPORT D'AUDIT TECHNIQUE, ANOMALIES & FEUILLE DE ROUTE

Analyse approfondie des vulnérabilités de sécurité, failles de confidentialité PIN, dysfonctionnements et opportunités d'amélioration de l'application ApexPOS

Projet :	ApexPOS — Application de Gestion Multi-Boutiques
Date de l'Audit :	21 Juillet 2026
Statut :	Document de Référence (Feuille de Route)
Version Application :	v2.4.1 (Backend Laravel API / Frontend React)
Périmètre révisé :	Isolation Tenant, Écran PIN, Rôles, TVA, Importation

TABLE DES MATIÈRES

1. Résumé Exécutif	Page 2
2. Matrice Synthétique des Anomalies	Page 2
3. Section Détaillée des Anomalies & Recommandations	Page 3
3.1 Anomalie 1 — Isolation Multi-Tenant & Confidentialité des Données	Page 3
3.2 Anomalie 1.1 — Fuite d'Identité & Exposition du SuperAdmin sur l'Écran PIN	Page 3
3.3 Anomalie 2 — Espace de Gestion des Boutiques, Rôles et Permissions	Page 4
3.4 Anomalie 3 — Configuration & Module de Gestion de la TVA	Page 4
3.5 Anomalie 4 — Dysfonctionnement du Processus d'Importation	Page 5
3.6 Anomalie 5 — Contrôle d'Accès, Matrice des Rôles et Héritage	Page 5
4. Conclusion & Plan d'Action Recommandé	Page 5

1. RÉSUMÉ EXÉCUTIF

Ce rapport formalise l'analyse détaillée des anomalies identifiées lors de la phase de test fonctionnel et de revue d'architecture de l'application ****ApexPOS****. Conformément aux directives, **aucune modification de code n'a été exécutée** dans cette étape. Ce document constitue la feuille de route d'audit officielle.

L'analyse révisée met en lumière des vulnérabilités critiques de sécurité sur l'**isolation inter-entreprises** et la **fuite d'information sur l'écran de connexion PIN** (exposition de la liste des entreprises hébergées et de la présence du Super Administrateur Global à des utilisateurs non autorisés ou des tiers).

2. MATRICE SYNTHÉTIQUE DES ANOMALIES

#	Intitulé de l'Anomalie	Domaine	Criticité	Priorité
1	Isolation Multi-Tenant & Confidentialité Données	Sécurité / Architecture	CRITIQUE	P1 — Immédiate
1.1	Fuite d'Identité & SuperAdmin sur Écran PIN	Sécurité / Authentification	CRITIQUE	P1 — Immédiate
2	Gestion des Boutiques & Utilisateurs	Administration / UX	ÉLEVÉE	P2 — Haute
3	Module & Paramétrage de la TVA	Finance / Réglementaire	MOYENNE	P3 — Moyenne
4	Dysfonctionnement de l'Importation	Données / Traitement	ÉLEVÉE	P2 — Haute
5	Matrice des Rôles & Héritage Permissions	Sécurité / Contrôle Accès	ÉLEVÉE	P2 — Haute

3. SECTION DÉTAILLÉE DES ANOMALIES & RECOMMANDATIONS

3.1 Anomalie 1 — Isolation Multi-Tenant & Confidentialité des Données

Niveau de Criticité : CRITIQUE	Priorité de traitement : P1 — Immédiate (Bloquant)
Périmètre impacté : Entités globales (Ventes, Produits, Clients, Caisses, Rapports)	Nature : Défaut d'étanchéité inter-entreprises (Cross-Tenant)

Reformulation Professionnelle :

L'architecture multi-tenant actuelle présente une vulnérabilité critique d'étanchéité des données. Chaque entreprise doit être totalement isolée. Les utilisateurs d'une entreprise ne doivent jamais pouvoir consulter les produits, ventes, clients, boutiques ou rapports d'une autre entreprise.

Analyse Technique & Impacts Potentiels :

- **Risque Réglementaire & Juridique :** Violation majeure de la confidentialité commerciale et non-conformité avec les règles RGPD.
- **Risque de Sécurité :** Risque de fuite d'informations commerciales stratégiques entre entreprises concurrentes.

Feuille de Route Recommandée :

1. Implémenter un *Global Scope* Eloquent obligatoire (ex: BelongsToTenant) appliqué par défaut sur tous les modèles.
2. Lier le middleware de tenanting (TenantMiddleware) au jeton d'authentification sans dépendre uniquement d'un header modifiable.

3.2 Anomalie 1.1 — Fuite d'Identité & Exposition du SuperAdmin sur l'Écran PIN

Niveau de Criticité : CRITIQUE	Priorité de traitement : P1 — Immédiate (Sécurité / Reconnaissance)
Périmètre impacté : Écran de connexion PIN (Auth), Liste publique des utilisateurs	Nature : Divulgence d'informations d'infrastructure & comptes sensibles

Reformulation Professionnelle :

Sur l'écran d'authentification par code PIN de caisse, l'application expose la liste des entreprises ainsi que les noms d'utilisateurs internes. De plus, le compte **Super Administrateur Global** y apparaît. Un client ou un utilisateur externe ne doit jamais connaître l'existence des autres entreprises hébergées, ni l'identité des employés d'autres structures, ni l'existence d'un compte SuperAdmin disposant de tous les accès.

Analyse Technique & Impacts Potentiels :

- **Fuite de Données d'Infrastructure (Reconnaissance) :** Exposer la liste des entreprises donne des indications précieuses à des tiers malveillants sur le portefeuille client du SaaS.
- **Attaque ciblée sur le SuperAdmin :** La présence visible du compte SuperAdmin sur un terminal de caisse public invite à des tentatives de force brute sur le code PIN (ex: 9999).
- **Violation de la Confidentialité Utilisateur :** Le personnel d'une entreprise A ne doit pas pouvoir voir les noms et visages des employés de l'entreprise B.

Feuille de Route Recommandée :

1. Masquer totalement le compte **Super Administrateur Global** de tous les sélecteurs publics de connexion PIN.
2. Restreindre l'écran PIN à l'entreprise courante (via sous-domaine dédié ou saisie initiale d'un code entreprise masqué).
3. Ne retourner via l'API PIN que les seuls utilisateurs actifs strictement rattachés à la succursale locale.

3.3 Anomalie 2 — Espace de Gestion des Boutiques, Rôles et Permissions

Niveau de Criticité : ÉLEVÉE**Priorité de traitement : P2 — Haute****Périmètre impacté :** Administration des succursales, Gestion des utilisateurs**Nature :** Incomplétude fonctionnelle de l'IHM d'administration**Reformulation Professionnelle :**

Il manque un espace dédié permettant aux administrateurs d'entreprise de gérer le réseau de boutiques (création, édition, activation/désactivation de points de vente), de gérer les utilisateurs, de les affecter à une boutique spécifique et d'attribuer des rôles et des permissions précises.

Analyse Technique & Impacts Potentiels :

- **Blocage Opérationnel :** Impossibilité pour un gérant de déployer une nouvelle boutique en autonomie.
- **Affectation Erronée :** Risque d'enregistrement de ventes sur la mauvaise succursale en l'absence de vérification.

Feuille de Route Recommandée :

1. Développer un écran "Boutiques & Succursales" avec CRUD complet et interrupteur Actif/Inactif.
2. Mettre en place un sélecteur de succursale d'affectation obligatoire dans la fiche de chaque utilisateur.

3.4 Anomalie 3 — Configuration & Module de Gestion de la TVA

Niveau de Criticité : MOYENNE**Priorité de traitement : P3 — Moyenne****Périmètre impacté :** Ventes POS, Achats Fournisseurs, Rapports Financiers**Nature :** Absence de paramétrage dynamique de la fiscalité**Reformulation Professionnelle :**

Il manque un véritable module de gestion de la TVA permettant la configuration dynamique du taux de TVA (taux multiples, exonérations, application automatique sur les ventes, prise en compte dans les achats et rapports déductibles).

Analyse Technique & Impacts Potentiels :

- **Non-Conformité Fiscale :** Erreurs sur les déclarations de TVA pour les entreprises sous régime d'exonération.
- **Calculs de Marge Faux :** Erreurs de calcul sur les marges si la TVA déductible des achats n'est pas paramétrable.

Feuille de Route Recommandée :

1. Ajouter un panneau de configuration de la TVA dans les Paramètres (taux %, interrupteur d'activation).
2. Permettre la sélection ou l'exonération de TVA directement sur l'écran de caisse POS et dans les bons d'achat.

3.5 Anomalie 4 — Dysfonctionnement du Processus d'Importation

Niveau de Criticité : ÉLEVÉE	Priorité de traitement : P2 — Haute (Investigation nécessaire)
Périmètre impacté : Import de catalogue produits, Fichiers CSV/Excel	Nature : Dysfonctionnement/Bug du processeur d'importation

- Reformulation Professionnelle :**
- La fonctionnalité d'importation de données présente un dysfonctionnement nécessitant une investigation approfondie avant toute correction (échecs de parsing, erreurs d'encodage, rejet de fichiers de produits valides).
- Feuille de Route Recommandée :**
- Conduire des tests de charge avec différents encodages (UTF-8, ISO-8859-1) et délimiteurs CSV.
 - Ajouter un système d'aperçu en mémoire avec validation de la structure de colonnes avant écriture.

3.6 Anomalie 5 — Contrôle d'Accès, Matrice des Rôles et Héritage

Niveau de Criticité : ÉLEVÉE	Priorité de traitement : P2 — Haute
Périmètre impacté : Matrice de privilèges, Middlewares d'autorisation API	Nature : Incohérence dans l'attribution des privilèges

- Reformulation Professionnelle :**
- Un problème a été observé dans la gestion des rôles et des permissions (attribution des rôles, permissions accordées, héritage, restrictions d'accès et cohérence globale des profils d'utilisateurs).
- Feuille de Route Recommandée :**
- Audit systématique de la grille Rôles x Permissions et passage à des *Laravel Policies* explicites.
 - Masquage dynamique côté Frontend React des boutons d'actions non autorisés selon le rôle connecté.

4. CONCLUSION & PLAN D'ACTION RECOMMANDÉ

Ce rapport établit l'inventaire officiel des anomalies à traiter avant le déploiement général d'ApexPOS. Les chantiers doivent être exécutés selon les 4 phases de la feuille de route ci-dessous :

Phase	Chantier Prioritaire	Objectif Majeur	Délai Recommandé
Phase 1	Multi-Tenant & Écran PIN (Anomalies 1 & 1.1)	Isolation stricte & Masquage du SuperAdmin / Entreprises	P1 — Immédiat (J+3)
Phase 2	Boutiques & Matrice Rôles (Anomalies 2 & 5)	Espace de gestion des boutiques, rôles et permissions	P2 — Étape 2 (J+7)
Phase 3	Fiabilité Importation (Anomalie 4)	Investigation et correction de l'import catalogue	P2 — Étape 3 (J+10)
Phase 4	Module TVA (Anomalie 3)	Paramétrage dynamique de la TVA (ventes/achats)	P3 — Étape 4 (J+14)

Note : Aucune modification de code n'a été effectuée à ce stade. Ce document fait foi de feuille de route officielle.